

Informe CAPEC 2025: Indicadores, Métricas y Tendencias en la Clasificación de Patrones de Ataque

Perspectiva Nacional (España) y Enfoque Comparativo Global

Resumen Ejecutivo

El paisaje de la ciberseguridad ha sufrido en 2025 una metamorfosis sin precedentes: los atacantes se han reinventado con inteligencia artificial generativa, los vectores de cadena de suministro se han duplicado, y los sistemas industriales han visto triplicarse las amenazas de actores estatales. En este contexto de sobreabundancia de amenazas —que un renacentista florentino contemplaría con horrorizada fascinación— el marco CAPEC (Common Attack Pattern Enumeration and Classification) de MITRE se erige como el vocabulario universal que permite a defensores, arquitectos y reguladores hablar del mismo adversario sin malentenderse.^[1]

El presente informe aborda exhaustivamente:

1. La arquitectura técnica del marco CAPEC v3.9 y sus indicadores intrínsecos de medición^[2]
2. Las tendencias emergentes de patrones de ataque desde 2025, con especial atención a la IA generativa, las cadenas de suministro de software y la criptografía post-cuántica
3. La aplicación territorial en España, incluyendo el paisaje de incidentes de INCIBE 2025, el nuevo Centro Nacional de Ciberseguridad y el ecosistema regulatorio NIS2/ENS^[3]^[4]
4. Una comparativa global mediante el Informe de Amenazas ENISA 2025^[5]^[6]
5. Propuestas de métricas nacionales derivadas de CAPEC para su integración en el Sistema de Gobernanza de Ciberseguridad español

1. Anatomía del Marco CAPEC: Fundamentos y Taxonomía

1.1 Génesis y Propósito Institucional

El proyecto CAPEC nació en 2007 bajo los auspicios del Departamento de Seguridad Nacional de los Estados Unidos (DHS), como componente de la iniciativa *Software Assurance* (SwA) de la Oficina de Ciberseguridad y Comunicaciones (CS&C). Desde entonces, su custodia ha recaído en la Corporación MITRE, organismo sin ánimo de lucro que opera centros de investigación y desarrollo federales financiados por el Gobierno estadounidense.^[7]^[8]

La versión actual, **CAPEC v3.9**, publicada el 24 de enero de 2023, cataloga un total de **559 patrones de ataque** estructurados en una jerarquía semántica de cuatro niveles: Categoría, Meta-Patrón, Patrón Estándar y Patrón Detallado. Esta arquitectura jerárquica no es mera taxonomía decorativa: permite al analista recorrer el árbol desde la abstracción estratégica hasta la implementación técnica específica, articulando tanto el pensamiento del arquitecto como el del penetration tester.^[9]^[2]

1.2 Las Dos Grandes Vistas del Universo CAPEC

CAPEC organiza su catálogo desde dos perspectivas complementarias:

Vista por Mecanismos de Ataque (View ID 1000): Clasifica los patrones según la técnica empleada para explotar una vulnerabilidad, independientemente del dominio objetivo. Comprende **9 categorías de nivel superior**:^[^10]

ID	Mecanismo	Descripción Operativa
156	Interacciones Engañosas	Suplantación de identidad, spoofing, phishing ^[^11]
210	Abuso de Funcionalidad Existente	Explotación de características legítimas del sistema
255	Manipulación de Estructuras de Datos	Buffer overflows, inyecciones, desbordamientos
262	Manipulación de Recursos del Sistema	Alteración de integridad SW/HW, cadena de suministro ^[^12]
152	Inyección de Ítems Inesperados	Inyección de código, SQL injection, command injection ^[^13]
(Emplear Técnicas Probabilísticas)	Fuerza bruta, ataques de diccionario	Explotación estadística
(Manipular Timing y Estado)	Race conditions, TOCTOU	Explotación temporal
(Recopilar y Analizar Información)	Reconocimiento, OSINT	Fase de inteligencia del ataque
(Subvertir Control de Acceso)	Escalada de privilegios, bypass de autenticación	Control de acceso

Vista por Dominios de Ataque (View ID 3000): Organiza los patrones según el dominio tecnológico objetivo:^[^14]

- Software — El dominio más poblado, con vectores web, aplicaciones empresariales y APIs
- Hardware — ASIC backdoors, firmware malicioso, side-channel attacks
- Comunicaciones — Ataques a protocolos de red, man-in-the-middle, interceptación
- Cadena de Suministro — Counterfeit Organizations (CAPEC-544), Malicious SW Updates
- Ingeniería Social — Phishing (CAPEC-98), Spear Phishing (CAPEC-163), Vishing (CAPEC-656)
- Seguridad Física — Jamming, GPS spoofing, acceso físico no autorizado^[^10]

1.3 Anatomía de un Patrón CAPEC: Los Indicadores Intrínsecos

Cada entrada del catálogo CAPEC no es un simple nombre: es una ficha técnica multidimensional que incorpora indicadores de medición estandarizados. Estos indicadores constituyen la base métrica del marco:^[^15]^[^16]

Indicadores de Vulnerabilidad (Susceptibility Indicators):^[16]

- **Positivos:** Condiciones que aumentan la probabilidad de éxito del ataque (p. ej., existencia de parámetros en URL para ataques de parameter tampering)
- **Negativos:** Condiciones que reducen la probabilidad de éxito (p. ej., ausencia de credenciales accesibles)
- **Inconclusos:** Condiciones ambiguas que requieren investigación adicional

Métricas de Severidad y Probabilidad:^[15]

- **Typical_Severity:** Escala ordinal {Muy Baja, Baja, Media, Alta, Muy Alta} — refleja el impacto típico si el ataque se ejecuta con éxito
- **Likelihood_of_Attack:** Escala ordinal {Muy Baja, Baja, Media, Alta, Muy Alta} — probabilidad de que un adversario intente el patrón
- **Typical_Likelihood_of_Exploit:** Escala ordinal idéntica — probabilidad de éxito considerando la superficie de ataque, habilidades requeridas y controles disponibles^[17]

Atributos Contextuales:

- **Requisitos de Habilidad del Atacante:** Define el nivel de sofisticación necesario
- **Recursos Requeridos:** Tiempo, acceso, equipamiento
- **Prerrequisitos del Ataque:** Condiciones necesarias para la ejecución exitosa
- **Flujo de Ejecución:** Secuencia de pasos — Exploración, Experimentación, Explotación
- **Consecuencias Típicas:** Impacto en Confidencialidad, Integridad, Disponibilidad

Relaciones y Mapeo:^[18]

- **Relaciones padre-hijo:** Los patrones de alto nivel agrupan implementaciones específicas
- **Mapeo a CWE:** Las debilidades subyacentes que cada patrón explota
- **Mapeo a CVEs:** A través de la cadena CAPEC→CWE→CVE
- **Mapeo a ATT&CK:** Técnicas y tácticas del adversario^[19]^[20]

2. El Ecosistema de Métricas CAPEC: Cómo se Mide lo que no se Puede Ver

2.1 El Modelo de Puntuación de Riesgo Compuesto

La investigación académica más reciente (2025-2026) ha formalizado un modelo de puntuación de riesgo que combina los indicadores CAPEC con los metadatos CWE para producir métricas cuantitativas accionables. El modelo propone:^[21]

$$\left[\begin{array}{l} \text{Riesgo}(w) = \text{Likelihood}(w) \times \text{Impact}(w) \\ \end{array} \right]$$

donde:

$$\left[\begin{array}{l} \text{Likelihood}(w) = \text{LA}\{\text{CAPEC}\}(w) \times \text{LE}\{\text{CWE}\}(w) \times \end{array} \right]$$

$\text{MI}(w)$

]

[

$\text{Impact}(w) = \text{TS}_{\text{CAPEC}}(w) \times \text{CC}(w)$

]

- LA: Likelihood of Attack (CAPEC)
- LE: Likelihood of Exploit (CWE)
- MI: Mode of Introduction (breadth multiplier)
- TS: Typical Severity (CAPEC)
- CC: Common Consequences breadth multiplier^[21]

Este modelo, de diseño deliberadamente conservador, asigna puntuaciones altas únicamente cuando tanto la viabilidad del ataque como la explotabilidad de la debilidad son elevadas simultáneamente, evitando así la inflación de riesgos que aqueja a tantos dashboards de CISO.^[21]

2.2 Métricas de Evaluación de Mapeo CVE-CAPEC

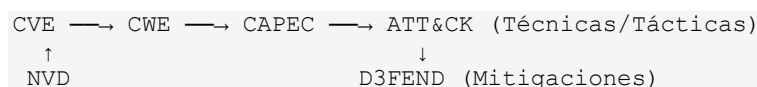
El problema de correlación entre vulnerabilidades concretas (CVEs) y patrones de ataque abstractos (CAPECs) ha generado una línea de investigación propia. Las métricas estándar empleadas son:^[22]

Métrica	Descripción	Interpretación para CAPEC
Recall@K	% de asociaciones correctas en el top-K del ranking	Mide cobertura: cuántos CAPECs relevantes se identifican
Precision@K	% del top-K que son asociaciones correctas	Mide precisión: qué tan "limpio" es el ranking
MRR (Mean Reciprocal Rank)	Inverso de la posición del primer resultado correcto	Mide si el CAPEC más relevante aparece primero ^[22]

La metodología ThreatLinker (arXiv, 2025) combina similitud semántica (SBERT) con búsqueda de palabras clave para calcular un *overall score* de asociación CVE-CAPEC, produciendo rankings que mejoran significativamente los enfoques puramente basados en semántica.^[18]

2.3 La Integración con el Ecosistema de Inteligencia de Amenazas

CAPEC no opera en solitario. Su valor reside en su posición de bisagra en el ecosistema de inteligencia de amenazas:^[20]^[19]



Esta cadena permite recorrer desde una vulnerabilidad concreta (CVE-2025-XXXX) hasta los patrones de ataque que la explotan, y desde ahí hasta las técnicas ATT&CK documentadas en incidentes reales y las contramedidas D3FEND correspondientes. Una reciente investigación publicada en SECURWARE 2025 demostró que enriquecer las descripciones de CVE con datos estructurados de CWE, CVSS, CPE y EPSS mejora la precisión del mapeo a tácticas ATT&CK hasta un 93,45%.^[19]

3. Tendencias Emergentes en Patrones de Ataque (2025-2026)

3.1 La IA Generativa como Amplificador de Patrones Clásicos

Si hay una tendencia que define el panorama de amenazas 2025 es la industrialización del ataque mediante inteligencia artificial. Pero —y aquí está el detalle revelador que los informes de marketing omiten— la IA no ha inventado nuevos patrones de ataque: ha **amplificado, acelerado y democratizado** los patrones ya catalogados en CAPEC. Los ataques de phishing (CAPEC-98) y spear phishing (CAPEC-163) han aumentado un 1.265% atribuido al crecimiento de herramientas de IA generativa. Los emails de phishing generados íntegramente por IA alcanzan una tasa de clicks un 42% superior a los escritos por humanos.^{[23][24]}

Los patrones CAPEC directamente impactados por la IA generativa incluyen:

- CAPEC-98 (Phishing) y CAPEC-163 (Spear Phishing): Potenciados por generación de contenido hiperpersonalizado en tiempo real^[25]
- CAPEC-195 (Principal Spoof): Los deepfakes de audio y vídeo permiten impersonaciones ejecutivas con una verosimilitud sin precedentes. Los ataques de voice phishing (vishing) crecieron un 442% en el primer semestre de 2024^[24]
- CAPEC-173 (Action Spoofing): Incremento de ataques ClickFix y SEO poisoning que combinan ingeniería social con código malicioso^[26]
- CAPEC-116 (Excavation): La IA acelera el reconocimiento OSINT al analizar en segundos datos de LinkedIn, repositorios públicos y fuentes abiertas^[27]

Nuevas fronteras: patrones de ataque específicos para sistemas de IA:^[28]

La publicación NIST AI 100-2e2025 (marzo 2025) formaliza la taxonomía de ataques contra modelos de machine learning:

Tipo de Ataque	Fase del ML	Descripción	CAPEC Relacionado
Evasion Attack	Inferencia	Perturbaciones adversariales para engañar al modelo	CAPEC-30 (análogo)
Poisoning Attack	Entrenamiento	Corrupción de datos de entrenamiento	CAPEC-186 (Malicious Update)
Model Extraction	Despliegue	Replicación del modelo mediante consultas repetidas	CAPEC-116 (Excavation)
Backdoor Attack	Entrenamiento	Inserción de triggers ocultos	CAPEC-204 (Lifting Sensitive Data)
Prompt Injection	Inferencia LLM	Manipulación de instrucciones del sistema	CAPEC-88 (OS Command Injection, análogo)

La inyección de prompts (Prompt Injection) ha emergido como el **LLM01:2025** según OWASP, con más de 461.640 intentos de ataque documentados en un único desafío de investigación. Su ausencia formal en el catálogo CAPEC v3.9 —que data de enero 2023— es una laguna crítica que la comunidad ya está abordando activamente, como demuestra la investigación publicada en arXiv en abril de 2026 sobre generación de código vulnerable usando LLMs para patrones CAPEC y CWE.^{[29][30][31]}

3.2 La Explosión de los Ataques a la Cadena de Suministro de Software

El patrón de ataque a la cadena de suministro (CAPEC-437, CAPEC-443, CAPEC-544, CAPEC-695) ha experimentado en 2025 una de las aceleraciones más dramáticas documentadas: **el número de ataques se duplicó** respecto a 2024, con una media de 26 incidentes mensuales desde abril de 2025, frente a los 13 mensuales del período anterior. En octubre de 2025 se alcanzó el pico histórico de 41 ataques en un solo mes.^{[32][33]}

Los vectores más empleados en 2025 dentro de la cadena de suministro incluyen:^[34]

- CAPEC-695 (Repo Jacking): El compromiso de tj-actions/changed-files (CVE-2025-30066) expuso secretos de CI/CD en logs públicos de decenas de repositorios^[34]
- CAPEC-691 (Spoof OSS Metadata): Manipulación de métricas de popularidad en ecosistemas de paquetes para engañar a desarrolladores
- CAPEC-673 (Developer Signing Malicious Software): Firma inadvertida de código alterado por desarrolladores comprometidos
- CAPEC-544 (Counterfeit Organizations): Creación de proveedores ficticios en la cadena de suministro crítica

La OWASP Top 10 2025 incluye por primera vez **Software Supply Chain Failures** en el tercer puesto de su lista para aplicaciones web, reflejo de esta realidad ineludible.^[35]

3.3 Amenazas Cuánticas: el Horizonte de CAPEC Post-Cuántico

Las amenazas relacionadas con la computación cuántica añaden una dimensión temporal única al modelado de riesgos con CAPEC. El informe de Capgemini (julio 2025) revela que casi dos tercios de las organizaciones consideran la computación cuántica como una amenaza inminente. Los patrones de ataque relevantes se distribuyen en tres horizontes temporales:[^36][^37]

Horizonte Inmediato (2025-2029) — Amenaza activa:

- **HNDL (Harvest Now, Decrypt Later):** El 67% de las organizaciones encuestadas ya están siendo objetivo de este ataque, que consiste en capturar tráfico cifrado hoy para descifrarlo cuando exista capacidad cuántica suficiente. Mapea con CAPEC-117 (Interception) amplificado con motivación de largo plazo.[^38]
- **Side-Channel en implementaciones PQC:** Las nuevas implementaciones de criptografía post-cuántica introducen vulnerabilidades de implementación que mapean a CAPEC-696 (Load Value Injection) y patrones de side-channel clásicos

Horizonte Medio (2030-2035) — Vulnerabilidades RSA/ECC:

- Algoritmo de Shor quebrando RSA y ECC en tiempo polinómico[^39]
- Algoritmo de Grover reduciendo a la mitad la seguridad efectiva de cifrado simétrico
- Mapeo a CAPEC-20 (Encryption Brute Forcing) potenciado exponencialmente

Horizonte Lejano (2035-2050) — Obsolescencia estructural:

- Transición obligatoria a algoritmos NIST PQC (ML-KEM, ML-DSA, SLH-DSA)
- Amenazas de implementación en hardware FPGA/ASIC[^36]

3.4 Zero Trust, Movimiento Lateral y Patrones de Abuso de Confianza

Los entornos Zero Trust (ZTA) han desplazado el perímetro de seguridad hacia la identidad y el contexto, redefiniendo qué patrones de ataque resultan más costosos para el adversario. Sin embargo, como señalaba el arquitecto del Templo de Salomón, la muralla más sólida siempre tiene una puerta trasera. Los patrones CAPEC más relevantes en arquitecturas ZTA incluyen:

- CAPEC-21 (Exploitation of Trusted Identifiers): Abuso de tokens de sesión, cookies y credenciales legítimas[^40]
- CAPEC-633 (Token Impersonation): Creación de tokens de acceso que suplantan entidades legítimas
- CAPEC-194 (Fake the Source of Data): Falsificación de origen en comunicaciones autenticadas
- CAPEC-22 (Exploiting Trust in Client): Explotación de la confianza implícita en canales cliente-servidor

El informe de Unit 42 (julio 2025) revela que la ingeniería social representó el **36% de todos los incidentes** de respuesta a incidentes, con grupos como Scattered Spider comprometiendo sistemas en menos de 40 minutos a través de manipulación de help-desk sin desplegar malware alguno.[^41]

4. España en el Mapa Global de Patrones de Ataque

4.1 El Panorama de Incidentes 2025: Una Radiografía de INCIBE

El balance del INCIBE para 2025 ofrece la fotografía más precisa del estado de las amenazas en territorio español:[^42][^4][^3]

Indicador	Cifra 2025	Variación	Patrón CAPEC Dominante
Incidentes totales gestionados	122.223	+26% vs 2024	—
Incidentes de malware	55.411	Tipo más frecuente	CAPEC-549 (Local Execution), CAPEC-440
Fraude online	45.445	+19%	CAPEC-98, CAPEC-194
Phishing	25.133	Líder en fraude	CAPEC-98 (Phishing), CAPEC-163
Ransomware	392	Alto impacto unitario	CAPEC-549, CAPEC-186
Robo de información	3.849	—	CAPEC-37 (Retrieve Embedded Sensitive Data)
Sistemas vulnerables notificados	237.028	—	Múltiples CAPECs
Dominios fraudulentos cerrados	4.600	—	CAPEC-543 (Counterfeit Websites)
Incidentes en operadores esenciales	401	—	CAPEC-437, CAPEC-439
Consultas línea 017	142.767	+44,9%	—

Los sectores esenciales más afectados en España, alineados con la Directiva NIS2, revelan un patrón de concentración notable:[^4][^42]

- **Banca:** 34% de los incidentes en operadores esenciales
- **Transporte:** 14%
- **Energía:** 8%
- **Infraestructuras de mercados financieros:** 7%
- **Aseguradoras y fondos de pensiones:** 6%

Kaspersky Security Bulletin detectó **más de 22 millones de ciberamenazas** en ordenadores españoles durante el cuarto trimestre de 2025 únicamente, de las cuales 9,2 millones llegaron por navegación web y 12,8 millones fueron incidentes locales. El 14,7% de los usuarios españoles fue afectado por ciberataques online, situando al país en el puesto 71 del ranking mundial.[^43]

4.2 España en el Contexto Europeo: El Informe ENISA 2025

El ENISA Threat Landscape 2025 analizó 4.875 incidentes entre julio de 2024 y junio de 2025, ofreciendo una perspectiva comparada de España en el contexto de la Unión Europea:[^6][^5]

Posición de España:

- **15,3% de los ciberataques gubernamentales** de la UE tuvieron como objetivo entidades españolas, situando al país en el cuarto lugar del ranking europeo, tras Francia (27%), Italia (26,3%) y Alemania (16,2%)[^5]
- **9,8%** de los objetivos ransomware en sistemas OT europeos[^44]
- La administración pública española concentra el mayor volumen de ataques hacktivistas DDoS[^45]

Tipología de Incidentes EU 2025 — Dominios CAPEC:

Tipo de Incidente	% Total EU	Patrón CAPEC Predominante
DDoS	76,7%	CAPEC-125 (Flooding), CAPEC-488
Ransomware (post-intrusión)	83,5% del malware	CAPEC-549, CAPEC-572
Phishing (vector de intrusión)	60% de intrusiones	CAPEC-98, CAPEC-163
Explotación de vulnerabilidades	21,3% de intrusiones	Multiple
Ciberespionaje	7,2% de incidentes	CAPEC-116, CAPEC-117
Ataques OT	18,2%	CAPEC-703 (ICS patterns)

Los actores de amenaza más activos contra Europa —y por extensión contra España— son grupos estatales como APT28, APT29, Turla, Sandworm (Rusia-nexo) y APT31, Mustang Panda, Salt Typhoon (China-nexo). La fabricación acumuló entre 20 y 30 ataques de cadena de suministro, junto con energía y salud.[^33][^5]

4.3 El Nuevo Ecosistema Regulatorio Español como Marco de Aplicación CAPEC

España ha experimentado en 2025 una renovación institucional de calado histórico en materia de ciberseguridad que transforma directamente el contexto de aplicación de CAPEC:

Centro Nacional de Ciberseguridad (CNC):[^46][^47]

Anunciado por el Presidente Sánchez en la clausura del ENISE XIX (octubre 2025, León), el CNC se adscribe directamente a la Presidencia del Gobierno y ejercerá como autoridad nacional de dirección, promoción y coordinación de ciberseguridad, alineada con los requisitos de la Directiva NIS2. Con una inversión de **1.157 millones de euros** en ciberseguridad y ciberdefensa, este es el mayor despliegue de capacidades cibernéticas en la historia española.[^47][^48]

Ley de Coordinación y Gobernanza de la Ciberseguridad:[^49]

Aprobada como anteproyecto en enero de 2025, transpone la Directiva NIS2 y la Directiva CER al

ordenamiento español, estableciendo el CNCS como autoridad supervisora. La ley diferencia entre **entidades esenciales** (energía, transporte, salud, agua, infraestructura digital, banca y administración pública) y **entidades importantes** (alimentación, industria química, gestión de residuos, servicios postales, fabricantes críticos y proveedores TIC).[⁵⁰]

Nueva Estrategia Nacional de Ciberseguridad:[⁵¹]

El Consejo de Seguridad Nacional aprobó en abril de 2025 el procedimiento para elaborar una nueva Estrategia Nacional de Ciberseguridad, que reconoce explícitamente como desafíos emergentes la inteligencia artificial y la computación cuántica.[⁵¹]

Estrategia de Ciberseguridad del SNS 2025-2028:[⁵²][⁵³]

Aprobada en noviembre de 2025 con 12 ejes estratégicos y 8 objetivos principales, esta estrategia sectorial del Sistema Nacional de Salud contempla gobernanza colaborativa entre el Ministerio de Sanidad y las CCAA.

Esquema Nacional de Seguridad (ENS, RD 311/2022):[⁵⁴][⁵⁵]

El ENS vigente establece la política de seguridad para la Administración Pública española con 7 principios básicos, 15 requisitos mínimos y hasta 73 medidas de seguridad, instrumentado mediante las guías CCN-STIC de la serie 800. La herramienta PILAR del CCN implementa el análisis de riesgos compatible con el ENS y es el vehículo natural para integrar indicadores CAPEC en el contexto regulatorio español.[⁵⁶]

5. Patrones de Ataque de Alta Prioridad: El Top 10 España 2025

Cruzando los datos del INCIBE 2025, ENISA 2025 y el catálogo CAPEC v3.9, emergen los siguientes patrones como los de mayor relevancia estratégica para el territorio español:

5.1 CAPEC-98 / CAPEC-163: Phishing y Spear Phishing

Relevancia España 2025: 25.133 incidentes documentados, vector inicial en el 60% de las intrusiones europeas. El phishing potenciado con IA generativa alcanzó el 79% de los ataques de ingeniería social registrados en 2025, frente al 35% de 2024.[⁵⁷][⁴²][⁵]

Indicadores CAPEC:

- Likelihood_of_Attack: **Alta**
- Typical_Severity: **Alta**
- Indicadores positivos de susceptibilidad: usuarios sin formación en concienciación, ausencia de autenticación multifactor, filtros de correo insuficientes

Vectores emergentes 2025: SEO poisoning (15,7% de casos en Unit 42), smishing con crecimiento del 2.900% desde 2023, deepfake video (23% de incidentes)[⁴¹][⁵⁷][²⁴]

Mitigaciones ENS:

- Implantación de MFA resistente a phishing (FIDO2/WebAuthn)

- Formación continua en concienciación (CCN-STIC 835)
- Filtrado avanzado de email con análisis de IA

5.2 CAPEC-549 / CAPEC-572: Ransomware y Explotación de Sistemas

Relevancia España 2025: 392 ataques ransomware documentados con alto impacto unitario; ransomware supone el 83,5% del malware post-intrusión en la UE. Los grupos de ransomware han adoptado el modelo RaaS (Ransomware-as-a-Service) con tácticas de doble extorsión.[⁴²][⁴⁵][⁵]

Indicadores CAPEC:

- Likelihood_of_Attack: **Media-Alta**
- Typical_Severity: **Muy Alta**
- Indicadores positivos: ausencia de segmentación de red, backups sin verificación, RDP expuesto a internet

Contexto España: CCN-CERT atribuye el 42% de los incidentes críticos a ataques dirigidos de ransomware y phishing. La Comunidad Valenciana sufrió acceso no autorizado a plataformas de salud electrónica documentado en el balance CCN-CERT.[⁵⁸]

5.3 CAPEC-125 / CAPEC-488: Ataques DDoS en Infraestructura Crítica

Relevancia España 2025: El 76,7% de los incidentes europeos fueron DDoS, con NoName057(16) como actor principal (66,7% de los ataques hacktivistas). España, con el CNC en proceso de constitución, es objetivo prioritario de campañas geopolíticas.[⁶]

Indicadores CAPEC:

- Likelihood_of_Attack: **Muy Alta** (para entidades gubernamentales y banca)
- Typical_Severity: **Media** (2% causa interrupción real)[⁶]
- Impacto estratégico: superior al técnico por efecto de desinformación

5.4 CAPEC-437 / CAPEC-443 / CAPEC-695: Ataques a Cadena de Suministro

Relevancia España 2025: Duplicación de incidentes globales. La energía, que supone el 8% de los incidentes en operadores esenciales españoles, es uno de los sectores más expuestos según ENISA 2025.[³²][⁴⁴][⁴²]

Indicadores CAPEC:

- Likelihood_of_Attack: **Alta** (sector energía, manufactura, TIC)
- Typical_Severity: **Muy Alta**
- CAPEC-695 (Repo Jacking): específico para cadenas de suministro de software[³⁴]

5.5 CAPEC-116 / CAPEC-117: Reconocimiento e Interceptación

Relevancia España 2025: Los grupos de ciberespionaje (APT28, Salt Typhoon) intensificaron operaciones contra administraciones públicas españolas. El 7,2% de los incidentes EU fueron espionaje, con impacto estratégico desproporcionado.[⁵]

5.6 CAPEC-703: Patrones ICS/OT — El Flanco Expuesto de las Infraestructuras Críticas

Relevancia España 2025: Los ataques OT representan el 18,2% de las ciberamenazas europeas. El informe Waterfall 2025 documenta que los actores estatales **triplicaron** su actividad contra infraestructura crítica, incluyendo jamming GPS generalizado. Spain Energy sector: 90% de las grandes empresas energéticas globales sufrieron una brecha de terceros en los 12 meses anteriores.^{[59][60][44]}

INCIBE-CERT publica estudios específicos sobre la aplicación de CAPEC en entornos ICS, confirmando la relevancia del View Slice CAPEC-703 para el sector industrial español.^{[8][61]}

6. Marco Propuesto de Indicadores CAPEC para la Gobernanza Nacional

6.1 Estructura de Indicadores para el CNC Español

La creación del Centro Nacional de Ciberseguridad ofrece una oportunidad histórica para institucionalizar métricas basadas en CAPEC. Se propone la siguiente arquitectura de indicadores en cuatro niveles:

Nivel I — Indicadores Estratégicos Nacionales (ISN)

Código	Indicador	Fuente CAPEC	Periodicidad
ISN-01	Tasa de incidentes por dominio CAPEC (SW, HW, SC, SE, COM, PHY)	Mapeo INCIBE-CAPEC	Trimestral
ISN-02	Índice de severidad ponderada nacional ($\Sigma \text{Typical_Severity} \times \text{Frecuencia}$)	CAPEC schema	Mensual
ISN-03	Cobertura de mitigación por mecanismo de ataque (% de los 9 mecanismos con control activo)	CAPEC-1000	Semestral
ISN-04	Tiempo medio de detección por patrón CAPEC (MTTD-CAPEC)	INCIBE + CAPEC	Trimestral
ISN-05	Evolución interanual de patrones CAPEC de muy alta probabilidad	CAPEC + ENISA	Anual

Nivel II — Indicadores Sectoriales (IS)

Para cada sector regulado por NIS2 (energía, banca, transporte, salud, TIC), se recomiendan indicadores específicos mapeados a los patrones CAPEC dominantes en cada sector:[^42][^5]

Sector	Patrones CAPEC Prioritarios	Indicador Clave
Banca (34% incidentes)	CAPEC-98, CAPEC-194, CAPEC-21	Tasa de compromiso de identidades
Transporte (14%)	CAPEC-627, CAPEC-703, CAPEC-437	Índice de exposición OT
Energía (8%)	CAPEC-703, CAPEC-186, CAPEC-437	Cobertura de segmentación IT/OT
Salud	CAPEC-549, CAPEC-98, CAPEC-116	% sistemas críticos con MFA
Administración Pública	CAPEC-125, CAPEC-98, CAPEC-544	Tiempo de respuesta DDoS

Nivel III — Indicadores de Madurez Organizacional (IMO)

Basados en los *Indicadores de Susceptibilidad* del esquema CAPEC, se proponen:[^16]

- **IMO-01:** % de indicadores positivos de susceptibilidad eliminados por categoría CAPEC
- **IMO-02:** Ratio de indicadores negativos (controles activos) vs positivos (vulnerabilidades presentes)
- **IMO-03:** Velocidad de remediación de debilidades CWE relacionadas con CAPECs de alta severidad

Nivel IV — Indicadores de Inteligencia de Amenazas (IIA)

- IIA-01: Distribución de actores adversariales por mecanismo CAPEC (trazabilidad de TTPs)
- IIA-02: Tasa de nuevos patrones CAPEC observados en incidentes reales (novedad vs patrones conocidos)
- IIA-03: Índice de correlación CVE-CAPEC en el inventario de vulnerabilidades nacionales (usando métricas Recall@K, Precision@K)[^22]

6.2 Integración con el Ecosistema de Herramientas CCN

La arquitectura de herramientas del Centro Criptológico Nacional ofrece el soporte técnico para implementar estos indicadores:

- PILAR: Análisis y gestión de riesgos compatible con ENS. Puede integrarse con taxonomías CAPEC para el mapeo de amenazas[^55][^62]
- INES: Monitorización del estado de seguridad de los sistemas de la Administración — candidato natural para incorporar dashboards de cobertura CAPEC
- AMPARO: Implantación del ENS — puede enriquecerse con los prerequisites y flujos de ejecución CAPEC para validar controles

La red nacional de SOC's articulada por el CCN constituye la infraestructura operativa para la recogida de datos que alimenten estos indicadores en tiempo real.^[^56]

7. Comparativa Internacional: CAPEC en los Sistemas de Medición de Ciberseguridad Nacional

7.1 El Índice Global de Ciberseguridad (GCI-ITU) y CAPEC

España ocupa el 4.º puesto conjunto en el Global Cybersecurity Index de la ITU, junto con Corea del Sur y Singapur. Este ranking valora la capacidad institucional y regulatoria, no el nivel de amenaza. La integración de métricas CAPEC en los informes nacionales reforzaría la trazabilidad entre postura de seguridad y exposición a patrones de ataque concretos.^[^56]

7.2 Modelos de Referencia Internacional

País/Organismo	Enfoque de Métricas de Ataque	Integración CAPEC
NIST CSF 2.0 (EEUU)	6 funciones: Govern, Identify, Protect, Detect, Respond, Recover ^[^63]	Referencia explícita para mapeo de amenazas
ENISA (UE)	Informe anual ETL con taxonomía de incidentes ^[^5]	Compatible con dominios CAPEC
CCN-CERT (España)	Guías CCN-STIC, PILAR, red de SOC's ^[^56]	Compatible, sin integración formal publicada
CISA (EEUU)	Known Exploited Vulnerabilities (KEV) + ATT&CK	CVE→CWE→CAPEC→ATT&CK
BSI (Alemania)	Lagen-Bericht anual	Mapeo implícito a CAPEC
NCSC (Reino Unido)	Active Cyber Defence + threat taxonomies	Compatibilidad declarada con CAPEC

El modelo estadounidense de integración CVE→CWE→CAPEC→ATT&CK en la base de datos NVD del NIST constituye el estándar de facto más sofisticado y es el candidato más natural para adopción en el nuevo CNC español.^[^19]

7.3 CAPEC como Lenguaje Común en Ejercicios de Ciberdefensa

La investigación de Security Compass (agosto 2025) documenta cómo CAPEC puede usarse para validar y enriquecer las categorías STRIDE en modelos de amenazas, añadiendo técnicas reales de adversario a las abstracciones teóricas. En los ejercicios de red team/blue team del ENISE XIX 2025 —bajo el lema "Un escudo digital para una España interconectada"— el uso de taxonomías compartidas es esencial para garantizar que el rojo y el azul hablen del mismo adversario.^{[^64][^65]}

8. Patrones Emergentes sin Cobertura Formal en CAPEC v3.9

Una auditoría honesta del catálogo CAPEC v3.9 revela lagunas que la comunidad deberá abordar en próximas versiones. Estos patrones de ataque observados en la naturaleza en 2025 carecen de entrada formal o tienen cobertura incompleta:

Patrón Emergente	Descripción	Estado CAPEC v3.9	Urgencia
LLM Prompt Injection	Manipulación de LLMs para eludir instrucciones del sistema	Sin entrada formal	● Crítica
AI Model Poisoning	Corrupción de datos de entrenamiento en pipelines MLOps	Parcial (CAPEC-186 análogo)	● Crítica
AI-Deepfake Social Engineering	Impersonación ejecutiva con audio/vídeo sintético	Parcial (CAPEC-173)	● Alta
HNDL Quantum Attack	Captura de tráfico cifrado para descifrado post-Q-Day	Sin entrada formal	● Alta
CI/CD Pipeline Injection	Envenenamiento de pipelines de integración continua	Parcial (CAPEC-695)	● Alta
MCP Server Exploitation	Explotación de servidores MCP (Model Context Protocol) para IA	Sin entrada (2025)[^21]	● Media
Shadow GenAI Data Exfiltration	Exfiltración mediante uso no corporativo de herramientas IA	Sin entrada formal	● Media

La investigación de arXiv (abril 2026) sobre generación de código usando LLMs para CAPEC y CWE y el framework de evaluación de riesgo para servidores MCP apuntan a que la comunidad académica está produciendo el material necesario para enriquecer el catálogo en su próxima iteración.[^31][^21]

9. Integración CAPEC con los Marcos de Modelado de Amenazas Establecidos

CAPEC no compite con otros marcos de modelado de amenazas: los enriquece. La siguiente tabla sitúa a CAPEC en el ecosistema metodológico:[^66][^67][^68]

Marco	Foco Principal	Rol de CAPEC	Sinergia
STRIDE	Categorías de amenazas abstractas (S, T, R, I, D, E)	Valida y enriquece cada categoría con técnicas reales[^64]	Alta
PASTA	Proceso de 7 etapas centrado en riesgo de negocio	CAPEC se usa en la Etapa 6 (Attack Modeling)[^66]	Muy Alta
OCTAVE	Identificación de activos críticos y riesgos operacionales	CAPEC proporciona el catálogo de amenazas[^67]	Alta
ATT&CK	TTPs de adversarios reales (post-intrusión)	CAPEC cubre ataque completo incluyendo fases pre-intrusión	Complementaria
D3FEND	Contramedidas defensivas	CAPEC→ATT&CK→D3FEND: cadena completa ataque-defensa	Alta
CVSS	Puntuación de vulnerabilidades individuales	CAPEC contextualiza el tipo de ataque que explota la CVE	Media
FAIR	Cuantificación financiera del riesgo	CAPEC proporciona la probabilidad y severidad del ataque[^17]	Alta
LINDDUN	Amenazas a la privacidad	CAPEC complementa con técnicas de extracción de datos	Media

La cadena más potente para el contexto español —especialmente para entidades bajo ENS, NIS2 y DORA— es la integración **CAPEC + ATT&CK + CVSS + FAIR**, que permite recorrer desde el patrón abstracto hasta el impacto financiero cuantificado, pasando por las técnicas adversariales documentadas en incidentes reales.

10. Resiliencia Digital y Continuidad de Negocio a través del Prisma CAPEC

10.1 De la Detección a la Resiliencia

El informe PwC Global Digital Trust Insights 2025, que encuestó a 4.042 ejecutivos de 77 países, revela una paradoja inquietante: las cuatro amenazas que más preocupan a las organizaciones —amenazas cloud, operaciones hack-and-leak, brechas de terceros y ataques a productos conectados— son las mismas para las que se sienten menos preparadas. Y únicamente el **2% de las organizaciones** han implementado acciones de resiliencia ciber en todas las áreas evaluadas.[^69]

Los patrones CAPEC relevantes para la resiliencia y continuidad de negocio se concentran en tres dominios:

Disponibilidad (CAPEC-125, CAPEC-130, CAPEC-197):

- Ataques de flooding, denegación de servicio por agotamiento de recursos, XML bomb
- Métricas de resiliencia: RTO/RPO por patrón CAPEC, porcentaje de tipos de ataque que el sistema puede detectar^[70]

Integridad (CAPEC-148, CAPEC-145, CAPEC-186):

- Spoofing de contenido, manipulación de checksums, actualizaciones maliciosas
- Métricas: tasa de detección de modificaciones no autorizadas, tiempo hasta detección de adulteración

Confidencialidad (CAPEC-116, CAPEC-117, CAPEC-37):

- Reconocimiento, interceptación, extracción de datos embebidos
- Métricas: volumen de datos exfiltrados por patrón, tiempo hasta detección de exfiltración

10.2 CAPEC en los Ejercicios de Tabla de Crisis (Tabletop Exercises)

El DoD Cyber Table Top Guide (versión 3, octubre 2025) establece metodología para ejercicios de crisis que puede adaptarse al contexto español. CAPEC proporciona la biblioteca de escenarios de ataque realistas que alimentan estos ejercicios, permitiendo que los equipos de continuidad de negocio practiquen respuestas a patrones de ataque concretos en lugar de escenarios abstractos.^[71]

11. Conclusiones y Recomendaciones Estratégicas

11.1 Síntesis del Panorama 2025

El análisis exhaustivo revela tres verdades incómodas y una oportunidad:

Verdad 1: Los 559 patrones de CAPEC v3.9 siguen siendo el vocabulario más preciso disponible para describir cómo se materializa una amenaza, pero el catálogo requiere actualización urgente para incorporar los patrones específicos de IA/LLM, computación cuántica y ataques a pipelines CI/CD que dominan el paisaje de amenazas 2025.

Verdad 2: España está en el top 5 europeo de países objetivo, con 122.223 incidentes documentados en 2025 y una superficie de ataque que crece en proporción directa a su digitalización. La creación del CNC y la inversión de 1.157 millones de euros son respuestas necesarias pero insuficientes si no van acompañadas de un sistema de métricas estructurado.^{[3][5]}

Verdad 3: La brecha entre el conocimiento teórico (CAPEC, ATT&CK, ENS, NIS2) y la implementación práctica medible es el problema real. El 2% de organizaciones con resiliencia implementada en todos los dominios es la cifra que ningún CISO debería presentar al Consejo de Administración sin un plan de mejora inmediata.^[69]

La Oportunidad: La convergencia de la Ley de Coordinación y Gobernanza de la Ciberseguridad, el nuevo CNC, la Estrategia Nacional en elaboración y el ENS actualizado crea el marco institucional

perfecto para institucionalizar un sistema de métricas CAPEC que convierta a España en referente europeo en medición del riesgo cibernético nacional.

11.2 Recomendaciones Accionables

Para el Centro Nacional de Ciberseguridad (CNC):

- Adoptar la cadena CVE→CWE→CAPEC→ATT&CK como ontología de amenazas nacional
- Establecer los ISN (Indicadores Estratégicos Nacionales) propuestos en la Sección 6.1
- Crear un grupo de trabajo CNC-INCIBE-CCN para mantener el mapeo de incidentes nacionales a patrones CAPEC en tiempo real

Para INCIBE-CERT:

- Enriquecer el balance anual de ciberseguridad con distribución de incidentes por dominio CAPEC
- Publicar mappings CAPEC para los principales grupos adversariales activos en España

Para el CCN y el ENS:

- Integrar los indicadores de susceptibilidad CAPEC (positivos/negativos) en las guías CCN-STIC relevantes
- Actualizar la herramienta PILAR para soportar mapeo explícito de amenazas a patrones CAPEC

Para las entidades bajo NIS2/ENS:

- Implementar evaluaciones de riesgo que incorporen `Likelihood_of_Attack` y `Typical_Severity` de los patrones CAPEC relevantes para su sector
- Mapear el catálogo de vulnerabilidades internas (CVE) a patrones CAPEC para contextualizar la priorización de remediación
- Incluir patrones CAPEC en los ejercicios tabletop anuales de continuidad de negocio

Para la comunidad académica y centros de investigación:

- Desarrollar metodologías de mapping CAPEC→NIS2 para los sectores regulados españoles
- Contribuir a la actualización del catálogo CAPEC con patrones emergentes de IA, computación cuántica y ecosistemas OT, siguiendo el modelo de investigación del INCIBE-CERT^[61]^[8]

Este informe ha sido elaborado con fuentes de primer nivel: organismos oficiales (INCIBE, CCN, MITRE, ENISA, NIST, BOE), publicaciones académicas revisadas por pares (arXiv, ACM, CEUR-WS, ThinkMind) e informes técnicos de primera línea (PwC, Capgemini, Unit 42, Waterfall Security, NTT DATA). Las cifras de incidentes corresponden a datos oficiales de 2025 y primer trimestre de 2026.

References

6.
CAPEC - Common Attack Pattern Enumeration and Classification ... - Common Attack Pattern Enumeration and Classification (CAPEC) is a list of software weaknesses.
7.
CAPEC List Version 3.9 - Mitre - Latest Version. The Common Attack Pattern Enumeration and Classification (CAPEC™) effort provides a ...
8.
Balance INCIBE 2025: 122.223 ciberincidentes en España (+26%) - INCIBE gestionó 122.223 ciberincidentes en 2025, un 26% más. 55.411 malware, 25.133 phishing, 392 ra...
9.
INCIBE detectó más de 122.000 incidentes de ciberseguridad en 2025 - Entre los incidentes más recurrentes en 2025 destacaron: Malware, con 55.411 casos, incluyendo virus...
10.
ENISA Threat Landscape 2025 Cybersecurity - Libertify.com - Phishing remains the undisputed king of initial intrusion vectors in the ENISA Threat Landscape 2025...
11.
ENISA 2025 Threat Landscape report highlights EU faces escalating ... - The 2025 Threat Landscape report highlights that DDoS attacks were the dominant incident type, accou...
12.
Common Attack Pattern Enumeration and Classification - Wikipedia
13.
CAPEC in the ICS world | INCIBE-CERT - Therefore, CAPEC is a catalog where the most common cyber-attacks can be reflected in order to help ...
14.
Common Attack Pattern Enumeration and Classification - Common Attack Pattern Enumeration and Classification (CAPEC) is a list of software weaknesses.
15.
Understand Common Attack Patterns in Cybersecurity - fnCyber - For example, CAPECs include an ID for tracking and correlation, attack name, high-level description,...

16.
CAPEC-1000: Mechanisms of Attack (Version 3.9) - Mitre - Attack patterns within this category focus on malicious interactions with a target in an attempt to ...
17.
CAPEC-262: Manipulate System Resources (Version 3.9) - Mitre - Attack patterns within this category focus on the adversary's ability to manipulate one or more reso...
18.
CAPEC-152: Inject Unexpected Items (Version 3.9) - Mitre - Attack patterns within this category focus on the ability to control or disrupt the behavior of a ta...
19.
CAPEC-3000: Domains of Attack (Version 3.9) - Mitre - In this attack pattern, the adversary leverages fuzzing to try to identify weaknesses in the system...
20.
[PDF] Common Attack Pattern Enumeration and Classification (CAPEC ... - This element represents the typical likelihood that the attack will succeed, and provides a likeliho...
21.
[PDF] Common Attack Pattern Enumeration and Classification (CAPEC ... - The purpose of this document is to define a standard schema for representing attack patterns and to ...
22.
[PDF] Assessing Risk of Security Non-compliance of Banking Security ... - To assess the risk, we use the CAPEC attack pattern classification⁶ to build a risk index model. The...
23.
ThreatLinker: An NLP-based Methodology to Automatically Estimate ... - CAPEC organizes attack patterns into hierarchical relationships, where complex or broad attack patte...
24.
[PDF] Mapping CVEs to the MITRE ATT&CK Framework - ThinkMind - This research demonstrates that supplementing CVE de- scriptions with structured data, such as softw...
25.
[PDF] A Large-Scale Automated Knowledge Graph for Threat Intelligence - Our methodology automates the collection and integration of heterogeneous cyber threat intelligence ...

26.
Risk assessment framework for open-source MCP servers - arXiv - Typical Severity (TS). This risk factor captures an overall average severity value for attacks that ...
27.
An NLP-based Methodology to Automatically Estimate CVE ... - arXiv - Based on the overall scores, we define a ranking –from the highest to the lowest score– of the attac...
28.
AI Cyber Attack Statistics 2025, Trends, Costs, Defense - DeepStrike - Rise of AI-assisted cyber attacks across industries in 2025, revealing a sharp 72% increase in incid...
29.
Social Engineering Statistics 2025: The Human Hack - See the latest 2025 statistics on social engineering attacks from phishing and BEC to AI deepfake sc...
30.
AI-Powered Cyber Threats in 2025: How Attackers Use Machine ... - In 2025, we're seeing a surge in AI-powered Cybercrime-as-a-Service (CaaS). Even low-skilled hackers...
31.
What's Trending: Top Cyber Attacker Techniques, March–May 2025 - Detect, Investigate, and Remediate Attacks at Every Stage. Get end-to-end coverage for 7 critical at...
32.
Social Engineering Attacks 2025: Evolving Threats and Defense ... - ... attack patterns ...
engineeringidentity threat detectionMFA bypassphishing 2025social engineerin...
33.
[PDF] Adversarial Machine Learning - NIST Technical Series Publications - An open challenge is to test and characterize the resilience of a variety of multi- modal ML models ...
34.
LLM01:2025 Prompt Injection - OWASP Gen AI Security Project - Prompt injection involves manipulating model responses through specific inputs to alter its behavior...
35.
What Is a Prompt Injection Attack? Definition, Examples - Proofpoint - Learn what a prompt injection attack is, how it works, and see real-world examples. Understand the r...

36.
Code Generation Using LLMs for CAPEC and CWE ... - arXiv - To address this challenge, we present a novel dataset that provides examples of vulnerable code snip...
37.
Supply Chain Attacks Surge In 2025: Double The Usual Rate - Supply chain attacks have doubled since April 2025, targeting IT and tech firms. Ransomware, data th...
38.
Software supply chain attacks surge, as ransomware groups ... - New Cyble data finds software supply chain attacks surge, as ransomware groups escalate and industri...
39.
12 Months That Changed Supply Chain Security - Silobreaker - Supply chain attacks in 2025 have escalated in both scale and sophistication, with threat actors exp...
40.
OWASP Top 10 2025: Software Supply Chain Failures - Blog - Software Supply Chain Failures ranks #3 in the OWASP Top 10 2025. Learn to mitigate this high-impact...
41.
Vi-C Hybrid Protocol...
42.
[PDF] Nearly two-thirds of organizations consider quantum computing as ...
43.
Quantum Computing Threats to Cryptography - Society - Background The emergence of quantum computing poses unprecedented threats to current cryptographic s...
44.
[PDF] Quantum computing threats to cybersecurity protocols
45.
CAPEC Attack Patterns – Overview & Directory - Explore the CAPEC Attack Patterns directory. Learn about common attack techniques and detailed descr...
46.
2025 Unit 42 Global Incident Response Report: Social Engineering ... - One of the most revealing trends we've observed is the rise of non-phishing vectors. ... Pie chart t...

47.
INCIBE gestionó 122.223 incidentes de ciberseguridad en 2025, un ... - En 2025 los incidentes más recurrentes fueron: Malware: 55.411 casos, incluidos 392 ataques de ransomware...
48.
España registra más de 22 millones de ciberamenazas en el último ... - Según el informe, un 14,7% de los usuarios en España se ha visto afectado por ciberataques online, l...
49.
ENISA Threat Landscape 2025: Critical OT Security Risks Every ... - ENISA's 2025 report reveals OT attacks now represent 18.2% of cyber threats. Manufacturing faces 59...
50.
ENISA Threat Landscape Briefing: 2024-2025 Analysis - This briefing document synthesizes the ENISA Threat Landscape (ETL) report for the period of July 20...
51.
Spain Launches New National Cybersecurity Centre - CIBERIA - This announcement coincides with an unprecedented investment: in 2025, the Government allocated €1.1...
52.
Pedro Sánchez announces the creation of the National ... - La Moncloa - Pedro Sánchez has announced the creation of the National Cybersecurity Centre, attached to the Presi...
53.
The Government approves a strengthening of Spain's cybersecurity ... - In 2024, more than 100,000 cyberattacks took place in Spain and every three days there was a cyberat...
54.
NIS2 Spain Transposition: Status, Requirements, and Roadmap - Deadline for Member States to transpose NIS2 into national law. Spanish Draft Approval, 14 January 2...
55.
The NIS2 Directive will transform cybersecurity in Spain - PKF Attest - The NIS2 Directive is the new European regulation that seeks to strengthen cybersecurity in all Memb...
56.
Orden PJC/522/2025, de 23 de mayo, por la que se ... - BOE-A-2025-10371 Orden PJC/522/2025, de 23 de mayo, por la que se publica el Acuerdo del Consejo de ...

57.
Aprobada la Estrategia de Ciberseguridad del Sistema Nacional de ... - La Estrategia establece un marco integral para proteger la información sanitaria, asegurar la contin...
58.
Aprobada la Estrategia de Ciberseguridad del Sistema Nacional de ... - La Estrategia establece un marco integral para proteger la información sanitaria, asegurar la contin...
59.
Esquema Nacional de Seguridad - Adecuación del ENS al nuevo marco normativo y al contexto estratégico existente para garantizar la s...
60.
Qué es el Esquema Nacional de Seguridad (ENS) - CNI - El Esquema Nacional de Seguridad, de aplicación a todo el Sector Público, así como a los proveedores...
61.
An Interview with Spain's National Cryptologic Centre (CCN) - This interview between Rubén Arcos and Spain's National Cryptologic Centre (CCN) was conducted via e...
62.
AI-driven social engineering attacks: 2025 trends - SoSafe - 53% of employees reported attack attempts on personal phones. 49% reported attacks aimed at personal...
63.
Ciberseguridad 2025 en España: amenazas, regulación, casos y ... - El 2025 está definiendo un escenario de ciberamenazas sin precedentes para las empresas españolas: a...
64.
Driving cybersecurity excellence in energy - Capco - Explore key cybersecurity risks in the energy sector, from OT vulnerabilities to supply chain threat...
65.
The 2025 OT Cyber Threat Report | Waterfall Security Solutions - The Waterfall Threat Report 2025 brings you comprehensive, verifiable data on cyber attacks that cau...
66.
Estudios | INCIBE-CERT - CAPEC in the ICS world ... CAPEC (Common Attack Pattern Enumeration and Classification) is a project...

67.
ESQUEMA NACIONAL DE SEGURIDAD (2025/1/5/1) - Formación - El curso se centrará en la identificación de necesidades y metodología para cumplir con el Esquema N...
68.
Understanding and Implementing the NIST CSF 2.0 Cybersecurity ... - NIST CSF is a risk-based compilation of guidelines that can help organizations identify, implement, ...
69.
How CAPEC Powers Better Threat Models and Security Requirements - In STRIDE models, CAPEC can be used to validate and enrich categories such as “Spoofing” and “Tamper...
70.
News in detail - Cybersecurity Coordination Office - Exchange of information and electronic data of all passengers entering the Spanish territory from no...
71.
Threat Modeling Methods: STRIDE, PASTA & DREAD - Process for Attack Simulation and Threat Analysis (PASTA) ... threats and underlying attack patterns...
72.
10 Types of Threat Modeling Methodology To Use in 2025 - The Process for Attack Simulation and Threat Analysis (PASTA) is a risk-focused 7-step threat modeli...
73.
Comparison of STRIDE, DREAD & PASTA - Software Secured - PASTA stands for Process for Attack Simulation and Threat Analysis. It is a seven-step methodology f...
74.
[PDF] Bridging the gaps to cyber resilience: The C-suite playbook
75.
[PDF] Cyber Resiliency Metrics, Measures of Effectiveness, and Scoring - Abstract. This report is intended to serve as a general reference for systems engineers, program man...
76.
[PDF] Department of Defense Cyber Table Top Guide - The Department of Defense (DoD) recognizes cyberspace as a warfighting domain and expects cyberspace...

CAPEC - Common Attack Pattern Enumeration and Classification ... - Common Attack Pattern Enumeration and Classification (CAPEC) is a list of software weaknesses.

CAPEC List Version 3.9 - Mitre - Latest Version. The Common Attack Pattern Enumeration and Classification (CAPEC™) effort provides a ...

Balance INCIBE 2025: 122.223 ciberincidentes en España (+26%) - INCIBE gestionó 122.223 ciberincidentes en 2025, un 26% más. 55.411 malware, 25.133 phishing, 392 ra...

INCIBE detectó más de 122.000 incidentes de ciberseguridad en 2025 - Entre los incidentes más recurrentes en 2025 destacaron: Malware, con 55.411 casos, incluyendo virus...

ENISA Threat Landscape 2025 Cybersecurity - Libertify.com - Phishing remains the undisputed king of initial intrusion vectors in the ENISA Threat Landscape 2025...

ENISA 2025 Threat Landscape report highlights EU faces escalating ... - The 2025 Threat Landscape report highlights that DDoS attacks were the dominant incident type, accou...

Common Attack Pattern Enumeration and Classification - Wikipedia

CAPEC in the ICS world | INCIBE-CERT - Therefore, CAPEC is a catalog where the most common cyber-attacks can be reflected in order to help ...

Common Attack Pattern Enumeration and Classification - Common Attack Pattern Enumeration and Classification (CAPEC) is a list of software weaknesses.

Understand Common Attack Patterns in Cybersecurity - fnCyber - For example, CAPECs include an ID for tracking and correlation, attack name, high-level description,...

CAPEC-1000: Mechanisms of Attack (Version 3.9) - Mitre - Attack patterns within this category focus on malicious interactions with a target in an attempt to ...

CAPEC-262: Manipulate System Resources (Version 3.9) - Mitre - Attack patterns within this category focus on the adversary's ability to manipulate one or more reso...

CAPEC-152: Inject Unexpected Items (Version 3.9) - Mitre - Attack patterns within this category focus on the ability to control or disrupt the behavior of a ta...

CAPEC-3000: Domains of Attack (Version 3.9) - Mitre - In this attack pattern, the adversary leverages fuzzing to try to identify weaknesses in the system....

[PDF] Common Attack Pattern Enumeration and Classification (CAPEC ... - This element represents the typical likelihood that the attack will succeed, and provides a likeliho...

[PDF] Common Attack Pattern Enumeration and Classification (CAPEC ... - The purpose of this document is to define a standard schema for representing attack patterns and to ...

[PDF] Assessing Risk of Security Non-compliance of Banking Security ... - To assess the risk, we use the CAPEC attack pattern classification⁶ to build a risk index model. The...

ThreatLinker: An NLP-based Methodology to Automatically Estimate ... - CAPEC organizes attack patterns into hierarchical relationships, where complex or broad attack patte...

[PDF] Mapping CVEs to the MITRE ATT&CK Framework - ThinkMind - This research demonstrates that supplementing CVE de- scriptions with structured data, such as softw...

[PDF] A Large-Scale Automated Knowledge Graph for Threat Intelligence - Our methodology automates the collection and integration of heterogeneous cyber threat intelligence ...

Risk assessment framework for open-source MCP servers - arXiv - Typical Severity (TS). This risk factor captures an overall average severity value for attacks that ...

An NLP-based Methodology to Automatically Estimate CVE ... - arXiv - Based on the overall scores, we define a ranking –from the highest to the lowest score– of the attac...

AI Cyber Attack Statistics 2025, Trends, Costs, Defense - DeepStrike - Rise of AI-assisted cyber attacks across industries in 2025, revealing a sharp 72% increase in incid...

Social Engineering Statistics 2025: The Human Hack - See the latest 2025 statistics on social engineering attacks from phishing and BEC to AI deepfake sc...

AI-Powered Cyber Threats in 2025: How Attackers Use Machine ... - In 2025, we're seeing a surge in AI-powered Cybercrime-as-a-Service (CaaS). Even low-skilled hackers...

What's Trending: Top Cyber Attacker Techniques, March–May 2025 - Detect, Investigate, and Remediate Attacks at Every Stage. Get end-to-end coverage for 7 critical at...

Social Engineering Attacks 2025: Evolving Threats and Defense ... - ... attack patterns ... engineeringidentity threat detectionMFA bypassphishing 2025social engineerin...

[PDF] Adversarial Machine Learning - NIST Technical Series Publications - An open challenge is to test and characterize the resilience of a variety of multi- modal ML models ...

LLM01:2025 Prompt Injection - OWASP Gen AI Security Project - Prompt injection involves manipulating model responses through specific inputs to alter its behavior...

What Is a Prompt Injection Attack? Definition, Examples - Proofpoint - Learn what a prompt injection attack is, how it works, and see real-world examples. Understand the r...

Code Generation Using LLMs for CAPEC and CWE ... - arXiv - To address this challenge, we present a novel dataset that provides examples of vulnerable code snip...

Supply Chain Attacks Surge In 2025: Double The Usual Rate - Supply chain attacks have doubled since April 2025, targeting IT and tech firms. Ransomware, data th...

Software supply chain attacks surge, as ransomware groups ... - New Cyble data finds software supply chain attacks surge, as ransomware groups escalate and industri...

12 Months That Changed Supply Chain Security - Silobreaker - Supply chain attacks in 2025 have escalated in both scale and sophistication, with threat actors exp...

OWASP Top 10 2025: Software Supply Chain Failures - Blog - Software Supply Chain Failures ranks #3 in the OWASP Top 10 2025. Learn to mitigate this high-impact...

Vi-C Hybrid Protocol...

[PDF] Nearly two-thirds of organizations consider quantum computing as ...

Quantum Computing Threats to Cryptography - Sciety - Background The emergence of quantum computing poses unprecedented threats to current cryptographic s...

[PDF] Quantum computing threats to cybersecurity protocols

CAPEC Attack Patterns – Overview & Directory - Explore the CAPEC Attack Patterns directory. Learn about common attack techniques and detailed descr...

2025 Unit 42 Global Incident Response Report: Social Engineering ... - One of the most revealing trends we've observed is the rise of non-phishing vectors. ... Pie chart t...

INCIBE gestionó 122.223 incidentes de ciberseguridad en 2025, un ... - En 2025 los incidentes más recurrentes fueron: Malware: 55.411 casos, incluidos 392 ataques de ranso...

España registra más de 22 millones de ciberamenazas en el último ... - Según el informe, un 14,7% de los usuarios en España se ha visto afectado por ciberataques online, l...

ENISA Threat Landscape 2025: Critical OT Security Risks Every ... - ENISA's 2025 report reveals OT attacks now represent 18.2% of cyber threats. Manufacturing faces 59....

ENISA Threat Landscape Briefing: 2024-2025 Analysis - This briefing document synthesizes the ENISA Threat Landscape (ETL) report for the period of July 20...

Spain Launches New National Cybersecurity Centre - CIBERIA - This announcement coincides with an unprecedented investment: in 2025, the Government allocated €1.1...

Pedro Sánchez announces the creation of the National ... - La Moncloa - Pedro Sánchez has announced the creation of the National Cybersecurity Centre, attached to the Presi...

The Government approves a strengthening of Spain's cybersecurity ... - In 2024, more than 100,000 cyberattacks took place in Spain and every three days there was a cyberat...

NIS2 Spain Transposition: Status, Requirements, and Roadmap - Deadline for Member States to transpose NIS2 into national law. Spanish Draft Approval, 14 January 2...

The NIS2 Directive will transform cybersecurity in Spain - PKF Attest - The NIS2 Directive is the new European regulation that seeks to strengthen cybersecurity in all Memb...

Orden PJC/522/2025, de 23 de mayo, por la que se ... - BOE-A-2025-10371 Orden PJC/522/2025, de 23 de mayo, por la que se publica el Acuerdo del Consejo de ...

Aprobada la Estrategia de Ciberseguridad del Sistema Nacional de ... - La Estrategia establece un marco integral para proteger la información sanitaria, asegurar la contin...

Aprobada la Estrategia de Ciberseguridad del Sistema Nacional de ... - La Estrategia establece un marco integral para proteger la información sanitaria, asegurar la contin...

Esquema Nacional de Seguridad - Adecuación del ENS al nuevo marco normativo y al contexto estratégico existente para garantizar la s...

Qué es el Esquema Nacional de Seguridad (ENS) - CNI - El Esquema Nacional de Seguridad, de aplicación a todo el Sector Público, así como a los proveedores...

An Interview with Spain's National Cryptologic Centre (CCN) - This interview between Rubén Arcos and Spain's National Cryptologic Centre (CCN) was conducted via e...

AI-driven social engineering attacks: 2025 trends - SoSafe - 53% of employees reported attack attempts on personal phones. 49% reported attacks aimed at personal...

Ciberseguridad 2025 en España: amenazas, regulación, casos y ... - El 2025 está definiendo un escenario de ciberamenazas sin precedentes para las empresas españolas: a...

Driving cybersecurity excellence in energy - Capco - Explore key cybersecurity risks in the energy sector, from OT vulnerabilities to supply chain threat...

The 2025 OT Cyber Threat Report | Waterfall Security Solutions - The Waterfall Threat Report 2025 brings you comprehensive, verifiable data on cyber attacks that cau...

Estudios | INCIBE-CERT - CAPEC in the ICS world ... CAPEC (Common Attack Pattern Enumeration and Classification) is a project...

ESQUEMA NACIONAL DE SEGURIDAD (2025/1/5/1) - Formación - El curso se centrará en la identificación de necesidades y metodología para cumplir con el Esquema N...

Understanding and Implementing the NIST CSF 2.0 Cybersecurity ... - NIST CSF is a risk-based compilation of guidelines that can help organizations identify, implement, ...

How CAPEC Powers Better Threat Models and Security Requirements - In STRIDE models, CAPEC can be used to validate and enrich categories such as “Spoofing” and “Tamper...”

News in detail - Cybersecurity Coordination Office - Exchange of information and electronic data of all passengers entering the Spanish territory from no...

Threat Modeling Methods: STRIDE, PASTA & DREAD - Process for Attack Simulation and Threat Analysis (PASTA) ... threats and underlying attack patterns...

10 Types of Threat Modeling Methodology To Use in 2025 - The Process for Attack Simulation and Threat Analysis (PASTA) is a risk-focused 7-step threat modeli...

Comparison of STRIDE, DREAD & PASTA - Software Secured - PASTA stands for Process for Attack Simulation and Threat Analysis. It is a seven-step methodology f...

[PDF] Bridging the gaps to cyber resilience: The C-suite playbook

[PDF] Cyber Resiliency Metrics, Measures of Effectiveness, and Scoring - Abstract. This report is intended to serve as a general reference for systems engineers, program man...

[PDF] Department of Defense Cyber Table Top Guide - The Department of Defense (DoD) recognizes cyberspace as a warfighting domain and expects cyberspace...